

Reporte Ejecutivo de Gestión de Riesgos de TI

Entidad: Clínica San Rafael | Destinatario: Directorio de la Clínica | Fecha: Septiembre de 2026

1. Resumen Ejecutivo

A raíz de la auditoría externa que detectó debilidades en la gestión de riesgos de la Clínica San Rafael, se realizó un relevamiento integral de los principales sistemas críticos institucionales (Historias Clínicas Electrónicas, base de datos de pacientes, sistema de facturación, red de equipamiento médico conectado, entre otros).

Mediante la plataforma SimpleRisk se identificaron **8 riesgos principales**, clasificados en:

- **1 Riesgo Crítico:** Requiere atención inmediata por su impacto en la operación.
- **5 Riesgos Altos:** Afectan la seguridad y disponibilidad de activos clave.
- **2 Riesgos Medios:** Vulnerabilidades a gestionar en el corto y mediano plazo.
- **0 Riesgos Bajos:** No se registraron hallazgos en esta categoría inicial.

2. Top 5 Riesgos por Nivel

ID	Riesgo	Activo Principal	Nivel	Valor
R01	Ransomware sobre HCE	Sistema HCE	Crítico	20
R02	Acceso no autorizado a HCE	Sistema HCE / BD pacientes	Alto	15
R04	Fuga de datos de pacientes	Base de datos pacientes	Alto	15
R03	Phishing al personal administrativo	Correo institucional	Alto	12
R06	Ataque a equipamiento médico conectado	Red médica (IoT)	Alto	10

Nota de priorización: Los riesgos R06 y R08 empatan en valor (10). Se prioriza R06 en este Top 5 porque su impacto es directo sobre la seguridad física del paciente (equipamiento médico), mientras que R08 (pérdida de backups) queda como sexto en orden de atención, sin restarle urgencia real a su tratamiento.

3. Estado de los Planes de Acción

Plan	Riesgo Mitigado	Responsable	Vencimiento	Estado
Backup 3-2-1 + EDR + segmentación	R01	Martín Sosa (Jefe de Sistemas/TI)	60 días	Pendiente
MFA + RBAC + auditoría en HCE	R02	Martín Sosa (Resp. Seguridad Info.)	45 días	Pendiente
Capacitación + MFA correo + doble verificación	R03	Federico García (Jefe Administrativo)	30 días	Pendiente

Inversión total estimada: USD 5.500 (desglosada en USD 3.500 para el Plan 1, USD 1.200 para el Plan 2 y USD 800 para el Plan

3), con plazos escalonados de ejecución entre 30 y 60 días.

4. Recomendaciones Prioritarias

1.

Aprobar e iniciar de inmediato el Plan 1 (backup + EDR): Mitiga el único riesgo Crítico (R01), protegiendo la continuidad de la atención médica.
 2. **Priorizar la implementación de MFA:** Aplicar segundo factor de autenticación tanto en el sistema de HCE como en el correo institucional para mitigar simultáneamente R02 y R03.
 3. **Segmentar la red de equipamiento médico conectado:** Ejecutar esta inversión por su impacto directo en la seguridad física de los pacientes y no solo como una medida informática.
 4. **Establecer revisiones trimestrales en SimpleRisk:** Mantener actualizado el registro de riesgos incorporando nuevas amenazas operativas.
 5. **Designar formalmente al Responsable de Seguridad de la Información:** Asignar el rol con dedicación para asegurar la gestión continua de los riesgos.
-